



भारतीय प्रौद्योगिकी संस्थान हैदराबाद
Indian Institute of Technology Hyderabad

CS6903: Network Security

(Module 1: Network Security Concepts)

Saurabh Kumar
CSE Department
IIT Hyderabad

Acknowledgement

- ❑ Instructors from previous course floating
 - Prof. Bheemarjuna Reddy Tamma, Prof. Kotaro Kataoka, Prof. Antony Franklin
- ❑ Professors from other Universities/Insitutes
 - Sandeep K. Shukla, Stefan Savage, Dan Boneh, Kirill Levchenko, Alex Gantman, Deian Stefan, Nadia Heninger, Alex Dent, Vitaly Shamtikov, Robert Turner
- ❑ Other internet sources

The Security Problem

- ❑ Lots of **buggy software**
- ❑ Social engineering is very effective (**gullible users**)
 - Art of manipulating people so they give up confidential information
- ❑ Money can be made from finding and exploiting vulnerabilities
 - Marketplace for vulnerabilities
 - Marketplace for owned machines (Pay-Per-Install)
 - Many methods to profit from owned machines

Why own machines?

1. IP address and bandwidth stealing

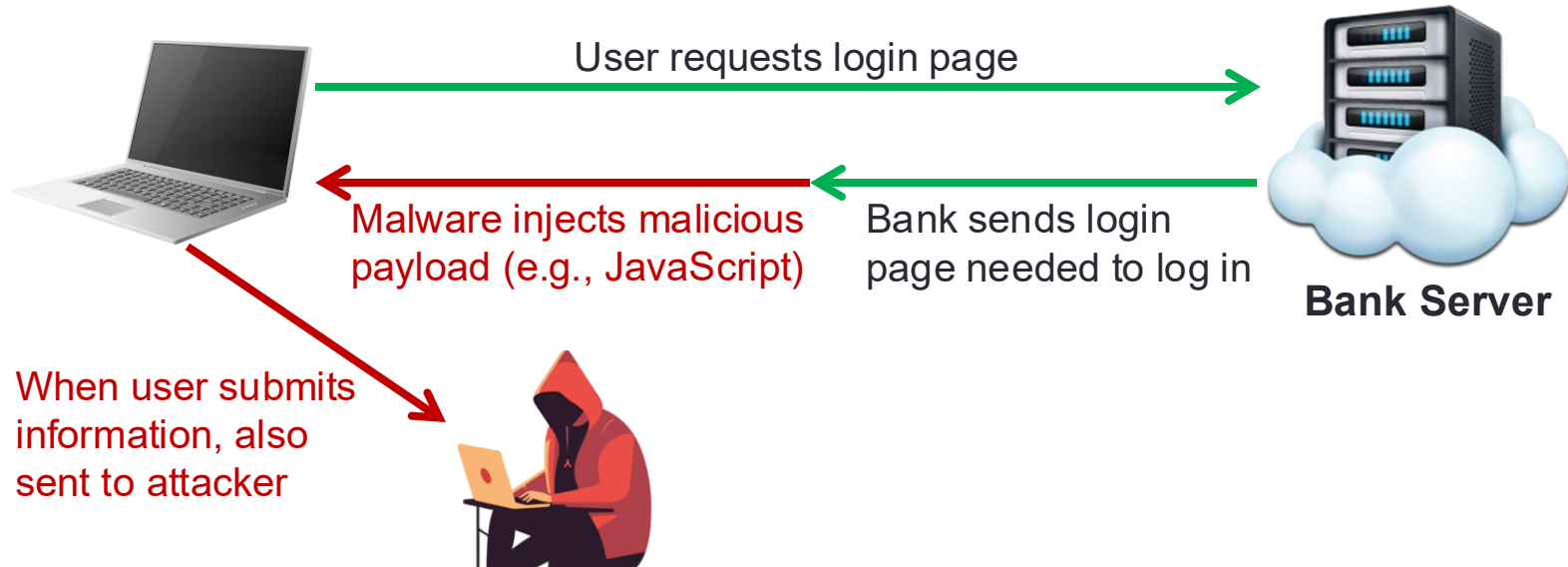
- ❑ Attacker's goal: look like a random internet user
- ❑ Use the IP address of infected machine or phone for
 - Spam
 - Denial of Service: Cost approximately \$20 per hour¹
 - Click Fraud (e.g. Clickbot.a)

1. <https://securelist.com/the-cost-of-launching-a-ddos-attack/77784>

Why own machines?

2. Steal user credentials and inject ads

- ❑ Keylog for banking password, web password, etc.
- ❑ Example: SilentBanker (and many like it)



Security

❑ Definition

- Refers to the overall practice of safeguarding assets, including people, physical property, information, and systems, against various threats

❑ Scope

- Includes **physical security** (locks, surveillance camera) and **information security** (protecting data and systems)
- Cover all domains; physical, digital, and organizational

❑ Focus/Objective

- Protection against a wide range of threats, both **tangible** (**theft**) and **intangible** (**insider fraud**)

❑ Examples

- Installing **locks on doors**, implementing **policies to secure access to sensitive documents**, etc.

Cybersecurity

❑ Definition

- Is a subset of security focused specially on protecting systems, networks, and digital data from cyber threats

❑ Scope

- Limited to the digital and technological realm
- Includes securing networks, applications, devices and data against threats like hacking, malware and phishing

❑ Focus/Objective

- Protection of cyberspace (interconnected technology environment) from cyberattacks, and ensuring Confidentiality, Integrity, and Availability (CIA trinity) of information

❑ Examples

- Using firewalls, IDS/IPS and encryption to protect networks and data, implement secure coding practice, penetration testing to identify bugs in software

Key Element of Cybersecurity

❑ Application Security

- Keeps software and devices free from **threats**

❑ Information Security

- Protects **integrity and privacy** of data, both in transit and at rest (stored)

❑ Network Security

- Secures networks from **intruders** by controlling network connections

❑ Disaster Recovery (DR) / Business Continuity Plan (BCP)

- **DR** policy dictates how an organization **recovers** from a **cyberattack** that causes data loss or affects operations
- **BCP**: Plan an organization falls back to while trying to operate w/o certain resources

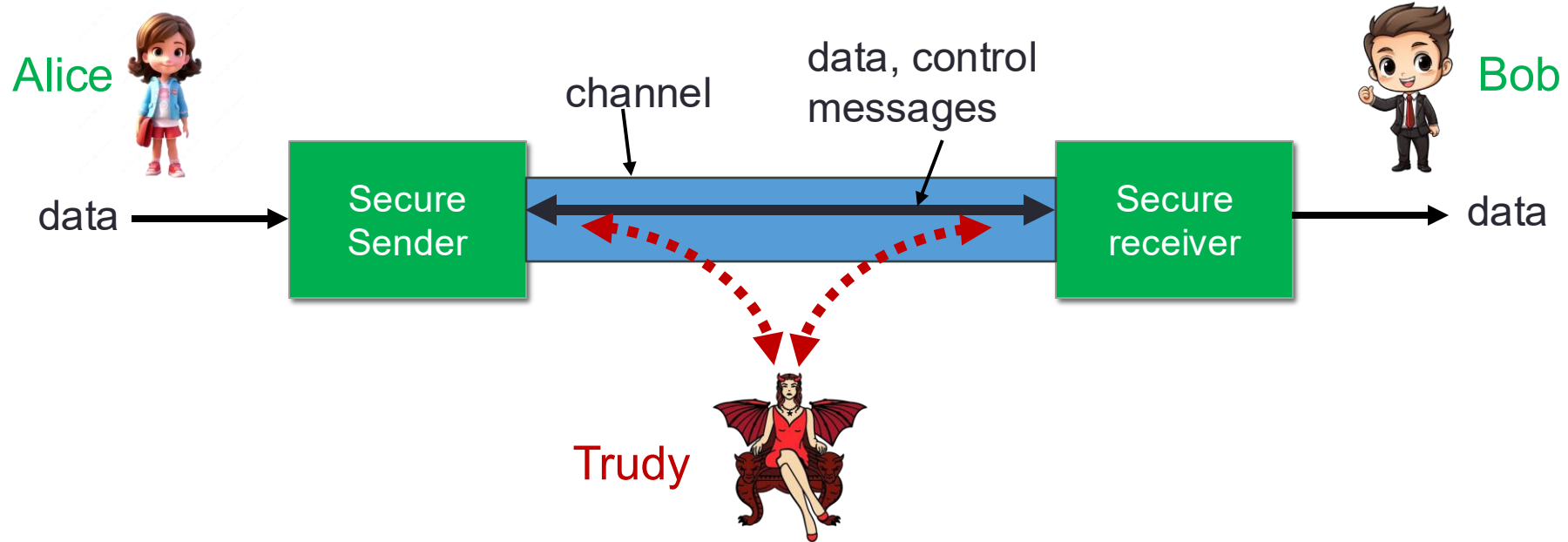
❑ Operational Security

- Includes procedures for **handling and protecting data & assets**

❑ End User Education

Friends and Enemies: Alice, Bob, Trudy

- ❑ Well known in network security and cryptography world
- ❑ **Alice** and **Bob** (lovers), want to communicate securely
- ❑ **Trudy** (intruder) may intercept, delete, add/modify messages



Who Might Alice and Bob Be?

Real life Alice and Bob

- ❑ Web browser/server for electronic transaction & web browsing
 - Online banking
 - Online purchases
 - Online chat, call, social networking Apps etc.
- ❑ DNS Server
- ❑ Router exchanging routing table updates
- ❑ Remote access
- ❑ File transfer, video streaming, emails, etc.

Many Bad Persons Out There!

❑ What can a **bad person** do?

❑ A Lot!

- **Eavesdrop**: intercept messages
- Actively **insert** messages into connection
- **Impersonation**: Can **fake (spoof)** source address in packet (or any field in packet)
- **Hijacking**: **Take over** ongoing connection by either removing sender or receiver, inserting himself/herself in place!
- **Denial of Service**: Prevent services from being used by others (e.g., by **overloading resources**)

Security Trinity: Confidentiality

- ❑ The property that data is not **disclosed** to system entities unless they have been **authorized** to know the data.
- ❑ A **breach of confidentiality** means that someone gains access to information who should not have access to it
- ❑ In the context of **network security**, only sender and intended receiver should **understand** message contents
 - sender encrypts message & receiver decrypts message
 - concealing the quantity or destination of communication (meta data) is called **traffic confidentiality**
 - [WhatsApp](#) vs Telegram vs [Signal](#)
 - [CNET article](#): Which secure messaging app you should use?

Security Trinity: Confidentiality...

❑ Not the same as privacy!

- **Confidentiality** is about **safeguarding your data** against **unauthorized access (data breaches)**
 - Confidentiality controls protect against the unauthorized use of your data already in the hands of an organization
- **Privacy** is about safeguarding **your identity and data** regardless of who has access to that information
 - Assures that individuals control or influence what info related to them may be collected and stored and by whom and to whom that info may be disclosed
 - UN recognized privacy as a human right in 1948!
 - Some info we share voluntarily when filling online forms
 - We can be monitored by companies, governments and unknown entities in this hyper-connected digital age
 - [EU's General Data Protection Regulation \(GDPR\)](#)
 - [India's Digital Personal Data Protection \(DPDP\) Bill, 2023](#)

Security Trinity: Integrity

- ❑ **Data integrity:** The property that data has not been **changed, destroyed, or lost** in an **unauthorized** or **accidental** manner
 - In the context of network security, sender and receiver want to ensure message is not altered in transit without detection by them
- ❑ **System integrity:** The quality that a system performs its intended function in an unimpaired manner, **free** from deliberate or inadvertent **unauthorized manipulation**
- ❑ **Integrity** also means ensuring **information authenticity & non-repudiation**

Security Trinity: Integrity

- ❑ **Authentication** ensures that you are really talking to whom you think you are talking
 - It involves verification of sender/receiver using passwords/certificates
- ❑ **Non-repudiation**: someone can't **repudiate (deny)** something.
 - It ensures that the sender of information is provided with proof of delivery and the recipient is provided with proof of the sender's **identity**, so neither can later deny having processed the info

Security Trinity: Availability

- ❑ The property of a system or a system resource being **accessible and usable** upon demand by an **authorized system** entity, according to performance specifications for the system
 - i.e., a system is available if it provides services according to the system design whenever users request them
- ❑ Turning off a computer provides **confidentiality** and **integrity**, but hurts **availability** very badly
- ❑ **Denial of Service (DoS)** attacks are direct assaults on availability

More Concepts: Threat Model

- ❑ A structured approach to identify, assess, and mitigate security risks associated with a system or application
- ❑ **Key Elements:**
 - Assets: What needs protection?
 - Threat: What can go wrong?
 - Vulnerabilities: What are the weaknesses?
 - Mitigations: How to reduce risks?
- ❑ **Example:** For a web application
 - Assets: User data
 - Threat: SQL Injection
 - Vulnerability: Lack of input validation
 - Mitigation: Use prepared statement, sanitize inputs

More Concepts: Vulnerability

- ❑ A flaw or weakness in system's defenses
 - It can be either at software, firmware, hardware, or service component level that can be exploited, causing a negative impact to confidentiality, integrity, or availability of the system
 - Vulnerabilities can allow attackers to run unauthorized code, access system information, and steal, modify or destroy data
 - Analogy: Fence with a hole or a house with unlocked door!
- ❑ Vulnerabilities in
 - Design or specification
 - Implementation bugs
 - Operation & Management
 - misconfiguration settings
 - weak passwords/default passwords

More Concepts: Vulnerability...

- ❑ Not every vulnerability results in an attack, and not every attack succeeds
 - Success depends on the degree of vulnerability, the strength of attacks, and the effectiveness of any countermeasures in place.
- ❑ Exposure refers to the state where vulnerability is visible/accessible and can potentially be exploited
 - Analogy: Leaving door wide open exposes vulnerability!
- ❑ Breach: An actual compromise of system/network leading to unauthorized access, data theft, etc
 - Analogy: Unauthorized entry into the house and theft

Vulnerability Disclosures in 2025¹

S. No.	Product Name	Vendor Name	Product Type	# Vulnerabilities
1	Linux Kernel	Linux	OS	5718
2	Windows Server 2025	Microsoft	OS	756
3	Windows Server 2022 23h2	Microsoft	OS	715
4	Windows Server 2022	Microsoft	OS	714
5	Windows Server 2019	Microsoft	OS	687
6	Windows 11 24H2	Microsoft	OS	680
7	Windows 11 23h2	Microsoft	OS	643
8	Macos	Apple	OS	620
9	Windows Server 2016	Microsoft	OS	612
10	Windows 10 22h2	Microsoft	OS	612
11	Windows 10 21h2	Microsoft	OS	610
12	Windows 11 22h2	Microsoft	OS	579
13	Windows 10 1809	Microsoft	OS	578
14	Windows 10 1607	Microsoft	OS	501
15	Windows Server 2012	Microsoft	OS	487

1. <https://www.cvedetails.com/top-50-products.php?year=2025>

Top 10 High Risk Vulnerability of 2025



More Concepts: Attacker

- ❑ Attacker: An adversary that is motivated and capable of exploiting a vulnerability in the system by launching attacks
 - Different attackers have different abilities
 - You can't design a secure system unless you know who the enemy is

“If you know your enemy and know yourself, you need not to fear the result of a hundred battles. If you know yourself but not enemy, for every victory gain, you will also suffer a defeat. If you know neither the enemy nor yourself, you will succumb in every battle”

Sun Tzu | The Art of War

More Concepts: Attacker...

❑ Types

- Individual
 - Outsider
 - Insider
 - Trusted/Privileged Insider
- Group
 - Ad Hoc
 - Establishes
- Organization
 - Competitor
 - Supplier
 - Partner/Customer
- State or State-sponsored

❑ Capabilities

- Time
- Money
- Training
- Access

❑ Motivation/Intent

- Curiosity
- Fame
- Money
- National Interest

More Concepts: Attack

- ❑ **Attack**: An intentional act by which an attacker attempts to evade security services & violate the security policy of a system
- ❑ **Passive vs Active Attacks**
 - **Passive** attack attempts to learn or make use of info from a system but does not affect resources of that system
 - Monitoring of network traffic
 - Very difficult to detect, but feasible to prevent them with encryption
 - **Active** attack attempts to alter system resources or affect its operation
 - Man-in-the-middle (MITM) & DoS attacks
 - Very difficult to prevent them due to wide variety of vulnerabilities
 - Main goal is to detect attacks and recover the system to normal operation

Attack on Networks



Eavesdropping



Main-in-the-middle
(MITM)



Denial of Service
(DoS)

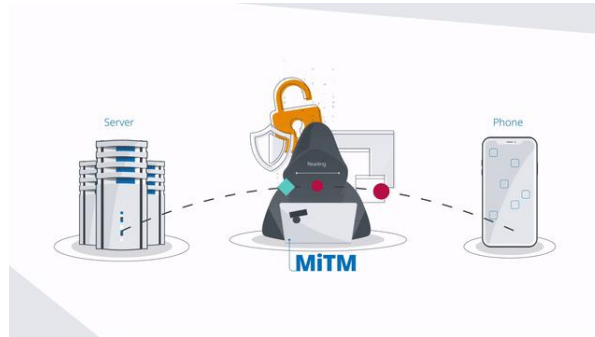
Eavesdropping

- ❑ Easy to intercept traffic, almost impossible to detect
- ❑ By default, everything is transmitted in clear text
 - Usernames, passwords, content ...
 - No security offered by the transmission medium
- ❑ Different tools available on Internet
 - Wireshark, tcpdump, airdump-ng, and many more
- ❑ With the right equipment, it's possible to eavesdrop from few kilometres away in wireless networks
- ❑ **Affects Confidentiality of data exchanged**
- ❑ **Countermeasures**
 - Encryption and signal-hiding techniques



MITM Attack

- ❑ Attacker intercepts, blocks or modifies communication between sender and receiver
- ❑ **Affects Confidentiality, Integrity, and Availability**



DoS Attack

- ❑ Attacks on higher levels
 - TCP SYN Flooding attacks
 - Ping of death, Ping flood attacks
 - Many more
- ❑ IP/MAC spoofing
- ❑ ARP spoofing
- ❑ Spoofed MAC control & management packets in Wi-Fi networks
 - Spoofed de-authentication / disassociation messages
 - Can target one specific user or entire network
- ❑ Frequency jamming
 - Not very technical, but works very well

